

REPORTE DE EVALUACIÓN DE VULNERABILIDADES

Auditoría de Seguridad en Servidor de Base de Datos Público

Autor: Ing. Mauro Alejandro Guadarrama García

Ingeniero en Sistemas Computacionales

Proyecto de Portafolio

Certificado Profesional de Ciberseguridad de Google

Junio 2026

1. Descripción del Sistema y Alcance

Descripción del Sistema: El hardware del servidor consta de un potente procesador de CPU y 128 GB de memoria. Se ejecuta en la última versión del sistema operativo Linux y aloja un sistema de gestión de bases de datos MySQL que almacena datos de clientes de la empresa de comercio electrónico. Está configurado con una conexión de red estable mediante direcciones IPv4 e interactúa con otros servidores de la red. Las medidas de seguridad actuales incluyen conexiones cifradas SSL/TLS.

Alcance: El alcance de esta evaluación de vulnerabilidad se relaciona con los controles de acceso actuales del sistema de base de datos remoto. La evaluación se centra en la exposición pública del servidor y cubre un análisis guiado por el marco NIST SP 800-30 Rev. 1.

2. Propósito de la Evaluación

El servidor de base de datos es el núcleo operativo de la empresa de comercio electrónico, ya que almacena información vital de los clientes y prospectos a los que acceden los empleados a nivel mundial. Proteger estos datos es de máxima prioridad para garantizar la privacidad del cliente, mantener la confianza y cumplir con las normativas internacionales de protección de datos. Si el servidor fuera comprometido o desactivado debido a un ataque, las operaciones de ventas globales se detendrían de inmediato, resultando en pérdidas financieras severas, daños irreparables a la reputación de la empresa y posibles sanciones legales.

3. Evaluación de Riesgos (NIST SP 800-30)

Fuente de la Amenaza	Evento de la Amenaza	Probabilidad	Gravedad	Riesgo Total
Hacker / Atacante Externo	Obtener información confidencial mediante exfiltración de datos.	3	3	9
Competidor	Robo de bases de datos de clientes para obtener ventaja en el mercado.	2	3	6
Hacker / Botnet	Sobrecarga del sistema mediante un ataque de Denegación de Servicio (DoS).	3	2	6

4. Enfoque de la Evaluación

Este informe utiliza una evaluación cualitativa de riesgos para comunicar el peligro inminente que representa un servidor expuesto al público. Se seleccionaron amenazas externas, como hackers y competidores, porque la configuración actual permite conexiones desde cualquier lugar de Internet sin filtrado de puertos. Al carecer de barreras de red, la probabilidad de que se intente un ataque automatizado (como fuerza bruta o DoS) es máxima (Nivel 3). La gravedad de la exfiltración de datos se clasificó como catastrófica (Nivel 3) debido a que la pérdida de la base de datos de comercio electrónico paralizaría el negocio por completo.

5. Estrategia de Remediación y Solución

Para asegurar el servidor de la base de datos y corregir la vulnerabilidad de exposición pública, se deben implementar medidas inmediatas de **defensa en profundidad**:

1. **Filtrado de Puertos y Firewall:** Configurar el cortafuegos perimetral para bloquear el tráfico público entrante al puerto de la base de datos (por ejemplo, el puerto 3306 para MySQL). El servidor ya no debe ser accesible libremente desde Internet.
2. **Red Privada Virtual (VPN):** Implementar una VPN obligatoria para los empleados remotos. El servidor solo debe aceptar consultas y conexiones originadas desde direcciones IP internas autorizadas o a través del túnel cifrado de la VPN empresarial.
3. **Autenticación Multifactor (MFA) y Principio de Mínimo Privilegio:** Requerir MFA para el acceso administrativo a la base de datos y asegurar que los empleados solo tengan acceso de lectura a los datos estrictamente necesarios para sus roles de ventas, revocando cualquier permiso administrativo excesivo.